

SECCIÓN 2.2



Confidencialidad, Integridad y Disponibilidad en escenarios reales

Temas de esta sección:

- Qué es la tríada CIA y por qué importa en ciberseguridad
- Confidencialidad aplicada a casos SOC reales
- Integridad aplicada a casos SOC reales
- Disponibilidad aplicada a casos SOC reales
- Cómo un mismo evento puede afectar más de un principio
- Impacto potencial vs impacto confirmado
- Errores comunes al analizar CIA



Para un analista SOC, la tríada CIA no es teoría. Es la herramienta para interpretar el posible impacto de una alerta.

C	Confidencialidad La información solo es accesible para quienes están autorizados.	Alertas SOC relacionadas: <i>Acceso no autorizado, descarga masiva, exposición de credenciales, exfiltración.</i>
I	Integridad La información y los sistemas no son modificados de forma no autorizada.	Alertas SOC relacionadas: <i>Cambio de configuración, modificación de permisos, alteración de logs, persistencia.</i>
A	Disponibilidad Los sistemas y servicios están accesibles cuando la organización los necesita.	Alertas SOC relacionadas: <i>DDoS, ransomware, caída de servidor, bloqueo de cuentas, eliminación de datos.</i>



Alerta SIEM

User:	comercial.rojas@empresa.com
Action:	Download files
Volume:	5.4 GB
Folder:	Clientes_Estrategicos_2025
Device:	Corporate laptop
Time:	22:50
Location:	Argentina
MFA:	Success

⚠️ **Posible impacto sobre CONFIDENCIALIDAD**

Podría haber exposición o uso indebido de información de clientes estratégicos.

Preguntas clave del analista:

- ¿El usuario suele acceder a esa carpeta?
- ¿El volumen es habitual?
- ¿El horario tiene sentido?
- ¿Hubo subida posterior a servicio externo?
- ¿El usuario está por dejar la empresa?
- ¿Hay actividad similar en otros usuarios?

La confidencialidad no se analiza solo por el acceso, sino por si ese acceso tiene sentido.



Alerta EDR

Alert:	Registry Run Key Modified
Host:	FIN-WS-044
User:	jperez
Key:	HKCU\...\CurrentVersion\Run
Value:	updater.exe
Path:	C:\Users\jperez\AppData\Roaming\
Parent:	powershell.exe
Time:	01:16

⚠️ **Posible impacto sobre INTEGRIDAD**

Se modificó una configuración del sistema. PowerShell modificó una clave de inicio automático, lo que puede indicar intento de persistencia.

Preguntas clave del analista:

- ¿Quién y qué proceso realizó el cambio?
- ¿El archivo existe? ¿Está firmado?
- ¿La ruta es esperada (AppData)?
- ¿Hubo descarga o conexión externa previa?
- ¿Hay otros hosts con el mismo comportamiento?
- ¿El cambio estaba aprobado?

No toda modificación es maliciosa, pero una modificación sensible desde PowerShell hacia una ruta de usuario requiere validación.

2.2 | Disponibilidad: ejemplo — Mass file modification (Ransomware)



Alerta SIEM:

Alert:	Mass file modification
Host:	FILE-SRV-02
Path:	\\filesrv02\Compartido\
Action:	High volume file rename
Extension:	*.locked
User:	svc_backup
Time:	03:22
Related:	Shadow copies deleted

Análisis de impacto CIA completo:

C	Confidencialidad: Antes del cifrado puede haber habido exfiltración.
I	Integridad: Los archivos fueron modificados o cifrados.
D	Disponibilidad: Los usuarios ya no pueden acceder a los archivos.

Un incidente real rara vez impacta un solo principio. El analista debe evaluar los tres.



Una diferencia crítica para el análisis SOC:

IMPACTO POTENCIAL	IMPACTO CONFIRMADO
Una actividad podría afectar la seguridad, pero todavía no hay evidencia suficiente de daño real.	Ya existe evidencia concreta de afectación.
<i>Ejemplo 1: Un usuario accedió a una carpeta sensible fuera de horario.</i>	<i>Ejemplo 1: El usuario descargó la carpeta y luego la subió a un servicio externo no autorizado.</i>
<i>Ejemplo 2: Se detectó ejecución de ransomware en un endpoint, pero el proceso fue bloqueado antes de cifrar archivos.</i>	<i>Ejemplo 2: Se detectó cifrado masivo de archivos y usuarios reportan pérdida de acceso.</i>

El analista debe ser cuidadoso con el lenguaje. No es lo mismo decir "podría haber impacto" que "hubo impacto confirmado". Esta diferencia afecta cómo escalás y cómo documentás.

2.2 | Escenario comparativo: mismo evento, distinto impacto



Evento base: User admin.sistemas modified shared folder permissions — 11:30 AM

CASO 1	Administrador, horario laboral, ticket aprobado, carpeta de pruebas.	Impacto probable: BAJO
CASO 2	Cuenta administrativa desde equipo no habitual, sin ticket, sobre carpeta con información financiera.	Impacto potencial: ALTO
CASO 3	Después del cambio, usuarios externos accedieron a archivos internos. Evidencia sólida.	Impacto CONFIRMADO (Confidencialidad)

El evento técnico es el mismo. La diferencia está en el contexto y en la evidencia posterior.

2.2 | Errores comunes al analizar CIA



Al analizar confidencialidad, integridad y disponibilidad, los errores más frecuentes son:

✗ Pensar que un evento solo puede afectar un principio

✓ Casi todos los incidentes reales afectan más de uno. Siempre evaluá los tres.

✗ Confirmar impacto sin evidencia suficiente

✓ Decir 'hubo exfiltración' sin poder demostrarlo daña la credibilidad del análisis.

✗ Confundir acceso exitoso con acceso legítimo

✓ Login exitoso + MFA ≠ actividad legítima. El contexto decide.

✗ Tratar toda caída de servicio como ciberincidente

✓ Puede ser falla de infraestructura, error de configuración o problema de proveedor.

✗ No diferenciar impacto potencial de impacto confirmado

✓ Afecta la priorización y la comunicación con los equipos de respuesta.

✗ Basarse solo en la severidad de la herramienta

✓ Una alerta 'crítica' en laboratorio puede ser menos urgente que una 'media' en producción.